個人情報漏えい 机上訓練 Slack投入用テキスト

当日 Slack へ投稿する文面集（コピー用）

取扱注意 ／ ファシリテーターのみ | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

実施日時: 2026-10-02（金）15:00 - 16:00
用途: 机上訓練のインジェクト（情報投入）を、実際のクライアント連絡と同じSlackで行うための文面集
シナリオ: 管理画面のログインレポートCSVダウンロード機能の不具合で、他社プロダクトのデータが混入したCSVを顧客がダウンロードできていた
投稿者: ファシリテーターが「取引先A社 田中さん」役として投稿する
前提: 全員リモート。連携はSlack
実施モード: **モードC（Slack完結型）** — **主催側からは会議を設定しない。** 開始告知・インジェクト・振り返り・クロージングをすべてSlackで行う（参加者が自分でハドルを立てるのは自由）

⚠️ 実施前に必ず読むこと

#	厳守事項
1	**実際のクライアントとのSlackチャンネル（Slack Connect含む）には絶対に投稿しない。** 誤爆すると本物のインシデントになります
2	訓練専用チャンネルを新規作成する。**チャンネルトピックに「【訓練用】ONBS-1998 机上訓練専用」と明記する**
3	**シナリオは誰にも事前共有しない**（藤原さんも訓練の対象）。停止権限はファシリテーターが持つ。オブザーバー（経営層）を置ける場合のみ、その人にだけ共有する
4	**訓練は必ずその日のうちに終了させ、ネタバラシまで行う。** 持ち帰らせない
5	参加者が本物のクライアントや社外に連絡しようとしたら、**即座に訓練であることを明かして止める**

チャンネル構成

片方だけを用意する。 社内対応用チャンネルを参加者が自分で立てるかが観測点になる。

チャンネル	用意するか	役割
`#2026_個人情報漏えい訓練`	**ファシリテーターが作る**	A社との共有チャンネル想定。田中さん役として投稿する場。参加者全員を招待
社内対応用チャンネル	**あえて用意しない**	参加者が作るかを観測する。作らなければそれ自体が発見

- **会議（Meet / ハドル）は主催側からは設定しない。** 参加者が自分で立てるのは自由（立てるかどうかが観測点）
- **A社との共有チャンネルで参加者が社内調整を始めても止めない。** 実際なら顧客に全部見えていた、という材料になる

抜き打ち度の選択

レベル	やり方	向いている場面
推奨（今回はこれ）	事前に「今日1時間、訓練をやります」と伝えたうえで、開始時にSlackへ投稿	初回。安全で、かつ十分に緊張感が出る
完全抜き打ち	予告なしにSlackへ投稿し、反応を見る	2回目以降。責任者への事前共有と、90分での強制終了ルールを必ずセットにする

今回は「予告あり × モードC（Slack完結型）」の組み合わせで実施します。
実施日時は予告しつつ、主催側からは会議を設定しません。参加者は通常業務の合間に反応する状態になり、
通知に気づくか・片手間で初動が回るかを観測します。
完全抜き打ちは、フローが整備されてからの実力テストに取っておいてください。

開始直前 — 鈴木さん（当事者エンジニア役）へのDM

リモートでは席順で情報の非対称を作れないため、DMで役の情報だけを渡す。

> 【訓練用・他の参加者には見せないでください】
>
> あなたは「管理画面の*ログインレポートCSVダウンロード機能*を、直近で改修したエンジニア」の役です。
>
> ・先月のリリースで、ログインレポートの集計ロジックに改修を入れました
> ・処理速度を上げるために集計クエリを書き直しています
> ・そのとき、*プロダクトIDでの絞り込みが一部の集計で効かなくなっていた*ことに、
> まだ気づいていません（自分の改修が原因だと結び付いていない状態です）
>
> *実際の作業は一切行わないでください。*
> この不具合は架空のものです。本番の管理画面・コード・リリース履歴を調べても何も出てきません。
> 調査しているふりも不要です。聞かれたことに「役として」答えるだけで構いません。
>
> 訓練が始まったら、この役として自然に振る舞ってください。
> 聞かれていないことを先回りして言う必要はありません。
> 無罰ルールなので、責められることはありません。
>
> なお訓練中、私から追加の情報をDMで送ります。
> 「そのまま貼ってください」と書いてあるものは、*要約せずそのまま* チャンネルへ貼ってください。
> あなたが調査して分かった、という設定です。

オープニング告知（0:00）

投稿先: `#2026_個人情報漏えい訓練`
投稿者: ファシリテーター（`@channel` を付ける）

> 主催側から会議を設定しないため、**この投稿がオープニングそのもの**になる。
> 長文は読まれない。冒頭3行に「1時間」「このチャンネルだけ見る」「終了時刻」を置く。
>
> **「会議はやりません」とは書かない。** ハドルやMeetを立ててはいけない、と受け取られる。
> 伝えたいのは「**こちらからは会議を設定しない**」であって、参加者が自分で立てるのは自由
> （むしろ立てるかどうかが観測点）。

@channel 【訓練開始】個人情報漏えいの机上訓練を始めます（15:00〜16:00）

・これから1時間、このチャンネルに連絡が流れます
・こちらからは会議を設定しません。普段の仕事をしながら、いつもどおり対応してください
　（必要だと思ったら、ハドルでもMeetでも自由に立てて構いません）
・実際のシステムには触りません。すべて架空の設定です

■ このチャンネルについて
このチャンネルは「*A社さんとの共有チャンネル（Slack Connect）*」という想定です。
ここに書いたことは、*すべてA社さんに見えている*と思って扱ってください。

■ 本番のつもりで動いてください
設定は架空ですが、*動き方は本番と同じにしてください。*
・「実際ならこうします」ではなく、*実際にやってください*（社内への連絡・判断・記録）
・A社さんへの返信も、*そのまま送る文面*をこのチャンネルに書いてください
・時間感覚も本番と同じです。「後で調べます」で止めず、*誰が・いつまでに、まで決めてください*
・ただし、*社外への実際の連絡と、実システムの操作だけはしないでください*

訓練だからと省略した動きは、本番でも省略されます。そこが今日いちばん見たいところです。

■ 今日のゴール
「うまく対応できること」ではありません。
*「決められなかったこと」を見つけること*がゴールです。
詰まったら、詰まったと書いてください。それが今日いちばん価値のあるアウトプットです。

■ ルール（4つだけ）
1. DMを使いたくなったら、先にこのチャンネルに「〇〇さんにDMします」と書いてください
2. 実際のシステムやコンソールは開かないでください
3. ハドルやMeetを立てるときは、記録のため @空 を入れてください
　（私は聞いているだけで、対応はしません。記録のための同席です）
4. ハドルや通話で決めたことは、必ずSlackに書き戻してください

■ 役割
一次受け: @椎名 ／ 統括判断: @藤原 ／ 調査: @鈴木 @文
進行: @空（私です）

■ 今日、私（空）は「休み」です
普段この手の対応には私も事実確認で入りますが、*今日は休暇で不在という設定*です。
進行役としてこのチャンネルにはいますが、*対応メンバーとしては存在しません。*
私に事実確認や判断を振らないでください（進め方の質問だけ受け付けます）。

実際のインシデントは、誰かが休みの日にも起きます。その日でも回るかを見たいためです。

> **「A社との共有チャンネルである」と先に明かすことで、観測の意味が変わる。**
> 「気づくか」ではなく「**分かっていても、つい社内の相談を書いてしまうか**」を見ることになる。
> 実際のSlack Connectでも共有チャンネルだと知ったうえで使うので、こちらのほうが本番に近い。
> 書いてしまっても**止めない。** 回数を数えて振り返りで示す。

無罰宣言（ファシリテーターが開始告知の直後に投稿する）

投稿先: 同上。**上の告知の直後に、空さん名義で投稿する。**

> 本来は責任者本人の口から出るほうが効くが、**藤原さんも今回は訓練の対象**であり、
> 事前に依頼するとシナリオの存在に勘づかれる。今回はファシリテーターが出す。
> **藤原さんが訓練の中で自分から無罰の方針を言うかどうかは、観測対象にする。**

補足です。

この訓練では、誰かのミスを責めません。実際の事故でも同じルールにします。
隠されるほうが会社にとって危険だからです。

実際に何かやってしまったときも、隠さず、すぐ言ってください。
早く言うほど被害が小さくなります。それだけです。

インジェクト① 第一報

投稿先: `#2026_個人情報漏えい訓練`
投稿タイミング: 0:05（**15:05**）
宛先: 椎名さん（一次受け / CS）にメンションを付けて投稿

> 投稿したら、**何も言わずに黙って待つ**。気づくまでの時間を測る（10分は助けない）。

@椎名　お世話になっております、A社の田中です。

管理画面からダウンロードしたログインレポートのCSV（ログイン数-2026090100-2026092523.csv）について
1点確認させてください。

弊社で内容を確認していたところ、弊社のユーザーではないアカウントのデータが
含まれているようでした。弊社のものではないユーザーグループ名が
いくつか見つかっています。

他社さんのデータが混ざってしまっている、ということはないでしょうか。
念のため、早めにご確認いただけると助かります。
よろしくお願いいたします。

【訓練】プレフィックス付き版（誤解防止を優先する場合）

> 【訓練】 ※これは机上訓練です。実際のインシデントではありません
> ――――――――――――――――――――
> @椎名 お世話になっております、A社の田中です。
>
> 管理画面からダウンロードしたログインレポートのCSV（ログイン数-2026090100-2026092523.csv）について
> 1点確認させてください。
>
> 弊社で内容を確認していたところ、弊社のユーザーではないアカウントのデータが
> 含まれているようでした。弊社のものではないユーザーグループ名が
> いくつか見つかっています。
>
> 他社さんのデータが混ざってしまっている、ということはないでしょうか。
> 念のため、早めにご確認いただけると助かります。
> よろしくお願いいたします。

インジェクト② 原因（鈴木さんへDM → 本人が報告）

渡し方: **ファシリテーターは直接投稿しない。鈴木さんへDMで送り、本人からチャンネルへ報告させる。**
タイミング: 椎名さん（CS）から鈴木さんへ話が渡った**数分後**（＝調査にかかった時間の再現）

状況	やること
鈴木さんに調査依頼が来ている	数分おいてDMを送る
まだ誰も聞きにきていない	**送らずに待つ。**「原因は誰が調べていますか？」とチャンネルに書いて促す
15:20 を過ぎても誰も聞きにこない	DMを送り、**「依頼されていないが自分で気づいて報告する」形で出してもらう。**自発的な報告だった事実を記録する

鈴木さんへ送るDM

> 【訓練・進行】調査結果が出た、という設定です。
> 下の「---」から下を、*そのまま* #2026_個人情報漏えい訓練 に貼ってください。
> （要約したり、言葉を足したりしないでください）
>
> ---
> 【調査中間報告】
> 管理画面のログインレポートCSVダウンロード機能で、集計クエリのプロダクトIDの絞り込みが
> 一部で効いていませんでした。先月のリリースから入っていた不具合です。
>
> A社がダウンロードしたCSVは約48,000行。他社プロダクトのデータが含まれています。
> 含まれる人数は現在集計中です。
>
> なお、この機能は全顧客が管理画面から自由に使えます。

インジェクト③ 集計結果（鈴木さんへDM → 本人が報告）＋ 投票

集計結果: ②と同じく**鈴木さんへDMし、本人からチャンネルへ報告させる**
投票: **ファシリテーターが直接投稿する**（訓練の仕掛けであり、社内の報告ではないため）
投稿タイミング: 0:26（**15:26**）

> **15:26 は死守する。** ここが訓練の中心。
> **15:24 までにDMを送り、「15:26 に貼ってください」と時刻を指定する。**
> それでも貼られない場合は、**15:28 にファシリテーターが代理投稿する**
> （「【進行】調査結果が出たものとして共有します」と前置きする）。

鈴木さんへ送るDM

> 【訓練・進行】集計が終わった、という設定です。
> 下の「---」から下を、*そのまま* 15:26 に #2026_個人情報漏えい訓練 へ貼ってください。
> （要約したり、言葉を足したりしないでください）
>
> ---
> 【集計結果】
> A社がダウンロードしたCSVに混入していたのは、他社プロダクト3件分。
> ユニークユーザー 1,240名
>
> 同じ期間に同じログインレポートをダウンロードした顧客は、A社を含めて計5社。
> 残る4社分の中身は現在確認中です。
>
> CSVの列（ログインレポート）:
> 日時 / 年 / 月 / 日 / 時 / ユーザーグループID / ユーザーグループ名 /
> ユーザーID / ユーザー名 / uuid / ユーザーエージェント / IPアドレス /
> リファラ / カスタムクエリ / OS / ブラウザ / デバイスタイプ / 解像度
>
> このうち個人に結びつくもの:
> ・ユーザー名（氏名）
> ・ユーザーID / uuid（個人を識別するID）
> ・IPアドレス / ユーザーエージェント / OS / ブラウザ / 解像度（端末の情報）
> ・リファラ（どの画面を見ていたか ＝ 行動履歴）
> ・カスタムクエリ（顧客側が任意に埋め込む値。中身は顧客ごとに異なる）
> ・ユーザーグループ名（所属企業名。個人情報ではないが、他社に見えれば取引先名が漏れる）

投票（ファシリテーターが直接投稿する）

鈴木さんの報告が貼られたのを確認してから投稿し、`:one:` `:two:` `:three:` のリアクションを付けておく。

> 【投票】これは個人情報保護法上の報告対象だと思いますか
>
> :one: 報告対象だと思う
> :two: 報告対象ではないと思う
> :three: 判断できない
>
> ※他の人のリアクションを見る前に、まず自分の考えで押してください

> 全員が押したら、**結果のスクリーンショットを記録係に保存させる。**
> Slackのリアクションは後から変えられるため、その場で撮る。

インジェクト④ 二次拡散の続報

投稿先: `#2026_個人情報漏えい訓練`
投稿タイミング: 0:41（**15:41**）

> 先ほどの件、追加でご報告です。
>
> 社内で確認したところ、ダウンロードしたCSVを部内の共有フォルダに置いてしまっていました。
> アクセスできる状態だったのは10名程度です。
> すでにフォルダからは削除しましたが、その前に個別にダウンロードした者がいるか
> どうかは現在確認中です。
>
> こちらの管理不足で申し訳ありません。
> 何か対応が必要でしたらお知らせください。

インジェクト⑤ 別の顧客からの問い合わせ（オプション / 75分版）

投稿先: `#2026_個人情報漏えい訓練`（影響を受けた別の顧客 B社役として投稿）
投稿タイミング: 0:47（**15:47**）

先に「場面転換アナウンス」を投稿する（必須）

オープニングでこのチャンネルを **「A社さんとの共有チャンネル」** と説明しているため、
そこへB社が現れると前提が壊れる。**訓練用チャンネルを増やさないかわりに、読み替えを宣言する。**
B社の投稿より先に、ファシリテーター名義で投稿すること。

> 【進行】ここから前提が1つ増えます。
>
> このチャンネルを、ここからは
> 「A社さんとの共有チャンネル」＋「B社さんとの共有チャンネル」を兼ねたものとして
> 読み替えてください。訓練用にチャンネルを増やさないための読み替えです。
>
> これ以降の投稿には、冒頭に相手先を書きます（【A社さんより】/【B社さんより】）。
> みなさんが返信するときも、冒頭に宛先を書いてください。
>
> ※ どちらのお客様にも、そのチャンネルの内容は見えている前提です。

> **宛先の書き分けそのものが観測点になる。** 宛先を間違えれば、
> **A社さん向けの説明がB社さんに見える**（＝今回のインシデントと同じ構図の二次事故）。
> 間違えても止めない。記録して振り返りで扱う。

B社からの問い合わせ

> 【B社さんより】
>
> お世話になっております、B社の佐藤です。
>
> A社さんの担当の方から連絡があり、弊社のユーザーデータが
> A社さんに渡っていた可能性があると伺いました。
>
> 事実関係を教えていただけますでしょうか。
> 弊社としても、社内および利用ユーザーへの説明が必要になります。
>
> また、この件は公表される予定はありますでしょうか。
> 弊社側の広報とも調整が必要なため、早めに方針を教えてください。

> B社が**当社ではなくA社経由で先に知った**という設定にしています。
> 「3社への連絡を後回しにするとどうなるか」を体感させるためのインジェクトです。

ファシリテーター用 応答パターン集

訓練中、参加者が「A社」に返信してきたときの応答例です。
参加者の判断の甘さが、そのまま不利な展開として返ってくるように設計しています。

参加者の返信	A社役の応答	狙い
「すぐ削除していただけますか」	「承知しました、削除しました。（少し置いて）……あ、もう手元にファイルは残っていません」	証拠が消えたことに気づかせる
「削除せずお待ちください」	「承知しました。こちらで保管しておきます」	正しい判断。そのまま進める
「Slackのファイルも消してください」	「消しました。Slackの履歴からも消えています」	**Slack上の証跡も消えることに気づかせる**
「確認しますのでお待ちください」（時間の言及なし）	「いつ頃までにご回答いただけますでしょうか。弊社でも社内報告が必要でして」	期限のコミットを迫る
「調査中です」だけで30分放置	「その後いかがでしょうか。弊社の情報システム部から状況確認を求められております」	中間報告の必要性に気づかせる
「何件くらい混ざっていましたか」と聞かれる	「弊社では正確には分かりません。ざっと見ただけで数十件は目に入りました」	相手任せにできないことを示す
「社外に共有していませんか」	（インジェクト④を前倒しで投入してよい）「実は共有フォルダに置いてしまっていて……」	良い質問には情報で報いる
「削除証明書をいただけますか」	「どういった形式で出せばよいでしょうか。書式をいただければ対応します」	書式がないことに気づかせる
「一度お電話でお話しできますか」	「はい、大丈夫です。ただ、後で経緯を確認したいので**記録は残していただけますか**」	音声で決めたことを書き戻す必要性に気づかせる
謝罪だけで具体的な次アクションがない	「恐れ入りますが、弊社としてはいつまでに何をご報告いただけるか知りたいのですが」	対外コミュニケーションの型がないことを露呈させる
「弊社の個人情報保護管理者から改めてご連絡します」	「承知しました。お待ちしております」	正しい判断。そのまま進める

参加者がこのチャンネルで社内調整を始めたら

止めないでください。 記録して、振り返りで扱います。

実際のSlack Connectでは顧客に全部見えているため、
「今日、社内の議論が何回A社さんに見えていたか」を数えて振り返りで示すのが最も効きます。

参加者が本物のクライアントに連絡しようとしたら

即座に訓練であることを明かして止めてください。

> ストップします。これは訓練です。実際の連絡はしないでください。
> ―今、実際に連絡しようとしたという判断そのものが、
> 振り返りで扱うべき重要なポイントです。メモしておいてください。

止めたこと自体を責めず、**「その判断は自然だった。だからこそフローが必要」**という文脈で扱います。

クロージング（0:58）

投稿先: `#2026_個人情報漏えい訓練`

> 【本日はここまで】お疲れさまでした。
>
> 今日出た「決められなかったこと」のリストが、そのまま対応フローの目次になります。
> ドラフトができたら、みなさんにレビューをお願いします。訓練の再実施はしません。
>
> 最後にもう一度だけ。
> 実際に何かやってしまったときは、隠さず、すぐ言ってください。
> 早く言うほど被害が小さくなります。それだけです。
>
> このあと資料を投稿します。今日の論点の解説が入っているので、後で目を通してください。

投稿したら、配布資料（03_参加者配布資料.pdf）と、
下の「訓練終了時のネタバラシ文面」を続けて投稿する。

訓練終了時のネタバラシ文面

投稿先: `#2026_個人情報漏えい訓練`（および参加者が作った社内対応チャンネル）

> 【訓練終了】
>
> お疲れさまでした。本日のやり取りはすべて机上訓練であり、
> 実際のインシデントは発生していません。
> 「A社の田中」「B社の佐藤」は訓練用の架空の担当者です。
>
> 実在のクライアントとは一切関係ありません。
> このチャンネルの内容は社外に共有しないでください。
>
> 今日出てきた「決められなかったこと」を、これから対応フローに変換していきます。
> ご協力ありがとうございました。

参加していないメンバーへの周知（必要な場合）

訓練用チャンネルが目に入る可能性のあるメンバーがいる場合、開始前に全体チャンネルへ投稿します。

> **参加者がどこで動くかは指定していない**ため、既存の社内チャンネルにインシデント対応の
> 相談が流れる可能性がある。**周知しておかないと、無関係のメンバーが本物の事故と誤認する。**
> 「新しく作られる場」だけでなく、**「いつものチャンネル」も対象に含めて書くこと。**

> 本日 15:00〜16:00 で、個人情報漏えいの机上訓練を実施します。
>
> #2026_個人情報漏えい訓練 で訓練用のやり取りが流れますが、すべて架空の設定です。
> 実際のインシデントではありませんので、ご安心ください。
>
> 訓練中、参加メンバーが新しいチャンネルを作ったりハドルを立てたりするほか、
> 既存の社内チャンネルでやり取りをすることがあります。
> この時間帯に「個人情報が漏えいした」「他社のデータが混ざっていた」といった
> 書き込みを見かけても、すべて訓練です。
>
> もし本物かどうか判断がつかない場合は、@空 まで直接ご確認ください。

訓練後の後片付け

- [ ] `#2026_個人情報漏えい訓練` を**アーカイブ**する（削除ではなくアーカイブ。記録として残す）
- [ ] 参加者が作った社内対応チャンネルも**アーカイブ**する
- [ ] 投票結果のスクリーンショットが保存されているか確認する
- [ ] 訓練中のやり取りのうち、振り返りに使う部分を振り返りシート（xlsx）へ転記する
- [ ] ネタバラシを投稿済みか確認する（**両方のチャンネルに**）
- [ ] 架空の会社名・担当者名が、実在の取引先と紛らわしくなかったか確認する（次回のシナリオ改善用）
